

Day 1 / Phase 4 - UI And API Security Hygiene

Generated: 2026-05-08

Objective

Check the production UI/API hygiene after the Mission Control restart:

- Browser/CSP security posture where available.
- Button contracts and route wiring.
- No fake buttons.
- No owner-facing secret/path leaks.
- No Tony active commander language.
- No OpenCloud architecture label, except literal legacy service naming for Build-Wiki / Farmer.

Result

****PARTIAL GO.**** Button-route wiring is production-proven and the strict API leak scan found no secret-shaped values or raw local path patterns in the checked live payloads. Owner-authenticated browser console proof remains blocked by the same browser-session blocker from Day 1 / Phase 3.

Remaining blockers:

Blocker	Impact
---	---
`owner_authenticated_browser_session_required`	Cannot inspect the owner's real browser console or visually confirm all panels from an owner session.
`production_security_scan_hardening_items_remain`	The built-in production security scan reports remaining credential/OS/runtime hardening warnings/failures.
`legacy_buildwiki_file_title_contains_opencloud`	One Build-Wiki file-list title still includes legacy OpenCloud wording. This appears as legacy content, not the current Gateway architecture label.

Commands And Routes Used

Check	Command / Route	Result
---	---	---
Static button contract route check	`node scripts/check-button-contract-routes.mjs`	PASS
Live production button contract check	`node scripts/check-button-contract-live-status.mjs` against local production bind	PASS
Primary API strict leak scan	Gateway, Agent Hub, Agent Zero, Hermes, Pi, Playwright MCP, Paperclip, SpaceAgent, button contracts	PASS
Extended API strict leak scan	Build-Wiki, Brain Sync, providers, capability matrix, connector readiness	PASS
CSP/security headers	`HEAD /login`	PASS/PARTIAL
Built-in security scan	`GET /api/security-scan`	PARTIAL, score 72/100

Button Contract Proof

Static route proof:

Metric	Value
---	---
Allowed button states	LIVE, READ_ONLY, BACKEND_REQUIRED, CREDENTIAL_REQUIRED, OWNER_APPROVAL_REQUIRED, DISABLED
API endpoints modeled	53
Missing route files	0
Allowed missing endpoint	`/api/notifications/stream`

Live production proof:

Metric	Value
Live endpoints checked	52
Skipped endpoints	1
Live contract failures	0

Notable live safety result:

Route	Live result	Meaning
`POST /api/bridge/brain-sync/build-wiki/run-now`	423	Build-Wiki Run Now is Bridge Session-gated and no longer creates an owner-channel approval outside scope.
`POST /api/zapier/request-write-approval`	423	Zapier write remains gated.
`POST /api/viral-crawl/video/request-run`	423	Video run remains gated.
Firecrawl write-like routes	503	Backend/credential remains blocked; no fake connected state.

CSP / Header Proof

The login route returns:

Header	Result
`x-frame-options`	`DENY`
`referrer-policy`	`strict-origin-when-cross-origin`
`content-security-policy`	Present

The CSP still permits inline styles and the configured trusted auth origins. No CSP was weakened in this phase.

Browser console proof is pending because an owner-authenticated browser session is not available from this execution environment.

API Leak Scan Proof

Strict leak scan patterns checked for raw local path and secret-shaped values, including local path prefixes, SMB URLs, `.env`, known token/key prefixes, private-key headers, database URLs, and bearer-token shapes.

Primary payload scan:

Route family	Strict leak hits
Gateway status/registry	0
Agent Hub status	0
Agent Zero status	0
Hermes status	0
Pi status	0
Playwright MCP status	0
Paperclip status	0
SpaceAgent browser status	0
Button contracts	0

Extended payload scan:

Route family	Strict leak hits
--------------	------------------

```
| Build-Wiki status/files/logs | 0 |
| Brain Sync status | 0 |
| Bridge providers | 0 |
| Capability matrix | 0 |
| Connector readiness | 0 |
```

The broader keyword-only scan found generic words such as `api\_key`, `secret`, and `token` inside status metadata. Those are labels/placeholders, not printed credential values. The strict scan found zero secret-shaped values.

OpenClaw+ / OpenCloud Naming Check

```
| Surface | Result |
| --- | --- |
| Agent Hub live payload | No OpenCloud architecture label found; only literal `
opencloud-docs-farmer.service` tokens appeared. |
| Build-Wiki status / capability matrix | Literal service-name references appear
ed as expected. |
| Build-Wiki files list | One legacy content title contains OpenCloud wording. |
| Current reports | OpenClaw+ is used as the runtime / skills / agents / mini-ag
ent execution layer. |
```

No new report or UI language was changed to use OpenCloud as an architecture layer.

Tony Commander Language Check

```
| Check | Result |
| --- | --- |
| Agent Hub live payload Tony active label scan | 0 hits |
| Agent Zero bridge contract | Tony retired/archive wording exists |
| Current architecture | Agent Zero remains commander |
```

Built-In Security Scan

The production security scan returned:

```
| Category | Score | Fails | Warnings |
| --- | ---: | ---: | ---: |
| Credentials | 60 | 1 | 0 |
| Network | 82 | 0 | 1 |
| OpenClaw+ | 81 | 0 | 3 |
| Runtime | 73 | 0 | 2 |
| OS | 64 | 1 | 5 |
| Overall | 72 | 2 | 11 |
```

Non-passing check IDs:

```
| Category | Check ID | Status | Notes |
| --- | --- | --- | --- |
| Credentials | `auth_pass` | fail | Requires credential/admin hardening review;
no secret printed. |
| Network | `hsts_enabled` | warn | Requires production header hardening review.
|
| OpenClaw+ | `exec_restricted` | warn | Needs runtime hardening phase. |
| OpenClaw+ | `tools_deny_list` | warn | Needs runtime hardening phase. |
| OpenClaw+ | `sandbox_mode` | warn | Needs runtime hardening phase. |
| Runtime | `backup_recent` | warn | Needs backup validation. |
| Runtime | `receipt_signing` | warn | Needs receipt signing review. |
| OS | `firewall` | warn | Needs host hardening review. |
| OS | `open_ports` | fail | Needs host hardening review. |
| OS | `disk_encryption` | warn | Host-level decision. |
```

```
| OS | `linux_core_dumps` | warn | Manual-only host hardening. |
| OS | `linux_mac_framework` | warn | Manual-only host hardening. |
| OS | `linux_tmp_noexec` | warn | Manual-only host hardening. |
```

No automatic hardening changes were applied in this phase because the campaign hard rules prohibit auth weakening and unreviewed destructive host changes.

Files Changed

```
| File | Purpose |
| --- | --- |
| `runtime/day-01-phase-04-ui-api-security-hygiene.md` | This report |
| `runtime/day-01-phase-04-ui-api-security-hygiene.pdf` | PDF rendering of this report |
```

Tests

```
| Test | Result |
| --- | --- |
| Static button route contract | PASS |
| Live button route contract | PASS |
| Strict primary API leak scan | PASS |
| Strict extended API leak scan | PASS |
| CSP/header check | PASS/PARTIAL |
| Built-in production security scan | PARTIAL |
```

Services

```
| Service | State |
| --- | --- |
| Mission Control | Active after Day 1 restart |
| Playwright MCP | Local-only status route reachable |
| Hermes gateway | Status route reachable; live adapter blocked |
| Paperclip bridge | Status route reachable; owner login blocked |
| Build-Wiki / Farmer | Run Now route Bridge-gated |
```

Commits

No commit has been created yet for this phase. This report will be included in the Day 1 isolated report commit after validation and secret scan.

Rollback

This phase writes reports only. Rollback is to revert the eventual Day 1 report commit if needed.

No-Secrets Confirmation

- No token value was printed.
- No API key value was printed.
- No auth file was printed.
- No `.env` file was modified.
- Live payload strict scans found zero secret-shaped values.

Updated Percentage

```
| System | Previous | Updated | Reason |
| --- | ---: | ---: | --- |
| Gateway / Agent Hub | 89% | 90% | Live button contract is clean after restart; owner-auth visual proof still blocked |
| Security / No-Fake UI | 86% | 88% | No fake button route failures and no strict API leaks; host hardening remains partial |
```

| Overall ecosystem | 90% | 90% | Meaningful hygiene proof improved, but hard blockers remain |

Exact Next Step

Continue to Day 1 / Phase 5: full Day 1 validation, staged secret scan, isolated report commit, push, and production pull for report artifacts.